

Acceptable Use Policy (AUP) template based on ISO/IEC27001:2022

1. Purpose

This Acceptable Use Policy establishes rules for the appropriate use of information systems, networks, medical systems, and data assets within the healthcare facility. It supports ISO 27001:2022 security controls for confidentiality, integrity, and availability.

2. Scope

This policy applies to all employees, contractors, students, third parties, and any entity accessing the facility's information systems, medical devices, networks, or patient data.

3. Responsibilities

- Users must comply with all security policies and procedures.
- Management must ensure enforcement and awareness.
- ICT and Security teams must implement technical controls and monitoring.

4. Acceptable Use Requirements

- Use systems only for authorized clinical, administrative, or research work.
- Access only data and systems necessary for assigned duties.
- Protect authentication credentials; passwords must not be shared.
- Ensure patient confidentiality at all times.

5. Unacceptable Use

- Unauthorized access to patient records or systems.
- Installation of unapproved software.
- Connecting personal devices to internal networks without authorization.
- Bypassing security controls, monitoring, or antivirus tools.
- Using facility resources for illegal, unethical, or personal business.

6. Email and Internet Use

- Email must be used responsibly; phishing reporting is mandatory.

- Internet browsing must support clinical or administrative functions.
- Downloading files from unknown sources is prohibited.

7. Data Protection and Privacy

- Protection of Personal Health Information (PHI)/ Personally Identifiable Information (PII) must follow legal and ISO 27001 requirements.
- Sensitive data must not be stored on personal devices.
- Encryption is mandatory for portable media.

8. Device and System Use

- Users must lock workstations when unattended.
- Only IT-approved devices may connect to medical or administrative networks.
- System logs and monitoring tools must not be tampered with.

9. Incident Reporting

Security incidents, data breaches, device loss, suspicious emails, and unauthorized access attempts must be reported immediately to the ICT Security Team.

10. Enforcement

Violation of this policy may result in disciplinary action, termination, or legal consequences.

11. Review

This policy will be reviewed annually or following major system or regulatory changes.